Handova

An initiative of **Ethical Bridge**

TRUST & SAFETY · POLICY

Data Protection Policy

With record of processing, ID-check impact assessment and breach procedure

How Handova collects, uses, protects and deletes personal information.

Version 1.0 | Approved 20 October 2026
Handova, an initiative of Ethical Bridge LLC

Skills handed over.
Capability that stays.

DOCUMENT CONTROL

About this document

DOCUMENT	Handova Data Protection Policy
TYPE	Policy
OWNER	Julieta Castiñeira de Dios
APPROVED BY	Julieta Castiñeira de Dios, founder, for Ethical Bridge LLC
VERSION	1.0
DATE OF APPROVAL	20 October 2026
NEXT REVIEW	October 2027, or sooner when Handova has a team, after a serious incident or when the law changes
APPLIES TO	The Handova team, volunteers and contractors; it explains how we treat the data of everyone who uses Handova
OPERATOR	Handova is an initiative of Ethical Bridge LLC, registered in Wyoming, USA
CONTACT	safeguarding@handova.org · hello@handova.org
LANGUAGE	English

CONTENTS

01 Purpose and scope
02 Roles and responsibilities
03 Principles
04 What we use data for, and on what basis
05 Data minimisation and privacy by design
06 Personal data shared within a contribution
07 Sharing, processors and international transfers
08 Security
09 Retention
10 Rights and how we handle requests
11 Automated decisions and AI
12 Children
13 Email, notifications and cookies
14 Personal data breaches
15 Obligations of the team, volunteers and contractors
16 Review and related documents
Annex A Record of processing
Annex B Data protection impact assessment — Didit identity check
Annex C Personal data breach procedure

PROPORTIONATE TO OUR SIZE

Handova is in its early stage. Today one person, the founder, runs both Handova and Ethical Bridge. This is our **first version**: it sets out what we do now and who does it. We will expand it as Handova grows and builds a team with dedicated safeguarding and compliance roles. Until then:

- **The founder is the safeguarding and privacy lead.** She receives reports, decides on protective action and keeps the records described here.
- **An independent contact** handles any concern about the founder, or that the founder is involved in, and covers urgent cases when the founder can't be reached for more than 48 hours. This is a trusted person outside Handova and Ethical Bridge: **to be confirmed soon**. They don't run Handova or investigate alone: they receive the concern, make sure it is handled fairly and get outside advice when needed.
- **We review this policy** at least once a year, as soon as Handova has a team, and after any serious incident.

AT A GLANCE

- We collect only what Handova needs to match professionals with non-profit organisations, record what they agreed and keep people safe.
- No beneficiary personal data on Handova by default. Needs, profiles and messages must not contain names, case files or identity documents of the people an organisation serves.
- If an organisation shares personal data with a professional for a contribution, the organisation is responsible for it (the "controller"), as the contribution agreement says.
- Identity checks use Didit and biometric data, so they run only with explicit, recorded consent. Handova keeps only the outcome and the name on the document.
- The administrator uses two-step sign-in, sees only what each task needs, and reads a conversation only once it has been reported.
- Signed agreements and contribution records are kept for six years after an account closes, then deleted. Everything else has a shorter, stated period.
- We answer every privacy request within one month and log it.
- Report any suspected data breach immediately to hello@handova.org. We decide within 72 hours whether to notify the relevant supervisory authority.

WHO THIS APPLIES TO

- **The Handova team:** today, the founder, who is the only administrator; in future, any administrator, volunteer, intern or contractor who can see Handova data.
- **Ethical Bridge LLC**, as operator of Handova.
- **Service providers** that process personal data for Handova (listed in Annex A).
- **Professionals and organisations**, for the data rules in the agreements they sign. Their own duties are set out in those agreements; this policy explains how Handova supports them.

SECTION 01

Purpose and scope

People trust Handova with their profiles, identity, work and concerns. This policy covers all personal data processed for Handova, in any form: database, file storage, email, spreadsheets, notes and screenshots.

Legal framework. Ethical Bridge LLC is registered in Wyoming, USA, and is subject to US federal and Wyoming law. People take part from many countries, so we also follow the law that applies where they are, including the EU and UK GDPR for personal data. Where rules differ, we follow the one that gives people more protection. In practice we work to the GDPR standard throughout, because many users are in the EU and our database is hosted in Frankfurt. Ethical Bridge LLC appoints an EU representative where Article 27 GDPR requires it. Where we must notify an authority, we notify the relevant supervisory authority.

SECTION 02

Roles and responsibilities

Controller. Ethical Bridge LLC, registered in Wyoming, USA, decides why and how Handova processes personal data and is accountable for this policy. Contact: hello@handova.org.

ROLE	WHO	RESPONSIBILITIES
Privacy lead	Julieta Castiñeira de Dios	Owns this policy and the annexes. Keeps the record of processing (Annex A). Approves DPIAs. Handles rights requests and breaches. Point of contact for authorities and individuals. As the only administrator, reviews profiles, needs and organisations, handles reports and follows section 8.
Independent contact	**to be confirmed soon**	A trusted person outside Handova and Ethical Bridge. Covers urgent breaches when the privacy lead is unavailable, and handles any request, breach or concern involving the privacy lead.
Everyone	Everyone with access to Handova data	Follows this policy, uses data only for their task, and reports breaches, concerns and rights requests the same day.

Other parties - **Organisations** are controllers for their own data and for any beneficiary or staff data they share with a professional under a contribution agreement. - **Professionals** use an organisation's personal data only on its instructions, for that contribution, and delete or return it at handover. - **Processors** (Supabase, Didit, Hostinger, Google, GitHub) process data only on our instructions, under a written agreement. - **EU representative:** appointed where Article 27 GDPR requires it. - **Data protection officer:** not appointed. We check once a year whether the law requires one, and record the answer.

SECTION 03

Principles

All processing follows these principles, and we keep records that show it.

1. **Lawful, fair and open.** Every use has a lawful basis and is explained in the privacy notice.
2. **Purpose limitation.** Data collected for matching, agreements or safety is not reused for unrelated purposes, such as advertising. We never sell data.
3. **Data minimisation.** We collect only what each step needs. We prefer totals, ID numbers and anonymised data.

4. **Accuracy.** People can see and correct their own profile at any time. Organisations review endorsements before they count, and professionals can request corrections.
5. **Storage limitation.** Data is deleted on the schedule in section 9 and Annex A.
6. **Security.** Data is protected by the measures in section 8.
7. **Accountability.** We document our choices: Annex A (record of processing), Annex B (DPIA), Annex C (breach procedure), the rights request log and the breach log.

SECTION 04

What we use data for, and on what basis

Each purpose has one main lawful basis, recorded in Annex A.

PURPOSE	LAWFUL BASIS
Accounts, profiles, needs, applications, messages, contribution agreements, hours, endorsements, impact CV, notifications	Contract: providing the service people signed up for
Reviewing profiles, organisations and needs before they are public; inactivity rule; keeping signature evidence; handling reports	Legitimate interests: keeping people safe, preventing misuse, evidence of what was agreed
Identity check with Didit	Explicit consent (biometric data is special category data)
Website analytics (Google Analytics)	Consent, through the cookie banner
Questionnaires, career stage, team size, six-month "still in use" check	Legitimate interests: learning whether Handova helps, reported only in totals
Contact from an independent evaluator	Consent, given once and recorded
Responding to authorities	Legal obligation, where the law requires it
Emergencies	Vital interests, only to protect someone's life

Legitimate interests. For each purpose that relies on legitimate interests, the privacy lead has recorded a short balancing test (why we need it, the impact on people, the safeguards). Approved with conditions by Julieta Castiñeira de Dios, 20 October 2026. The conditions are the safeguards in sections 5, 8 and 9 and Annex A.

Special category and criminal offence data. We do not ask for health, religion, ethnicity, sexual orientation or similar data. The only special category data we process is biometric data in the Didit check (Annex B). We do not collect criminal records. Professionals tick a declaration that they have no relevant dismissals or convictions; we keep only the signed confirmation, never details. Free-text fields (introductions, messages, questionnaire answers, reports) can reveal sensitive information. We do not ask for it, we restrict access to it, and we delete it on schedule.

Consent. Where we rely on consent, it is a clear, separate action; we record when and how it was given; and it can be withdrawn as easily as it was given.

SECTION 05

Data minimisation and privacy by design

- **No beneficiary personal data by default.** Every need confirms it involves no direct contact with children or adults at risk and no access to their personal information. Handova reviews every need before it opens and asks for

changes if it contains personal details.

- Profiles, needs and messages must not include beneficiary names, case files, identity documents or confidential research.
- Notification emails never include what people write in Messages or the free-text reasons people give.
- Profiles are private until the person publishes them and Handova approves them. Impact CV entries are public only if the professional chooses.
- Questionnaire answers, career stage and "would you work together again" answers are visible only to Handova and are reported only as totals.
- Handova stores the outcome of an identity check and the name on the document, never the document or selfie.
- Before we launch a new feature, data set or provider, the privacy lead screens it for privacy risk and updates Annex A. A DPIA is required for processing likely to be high risk, including biometric checks, profiling or ranking people, AI that assesses people or content, and any processing of children's data or data about adults at risk.

SECTION 06

Personal data shared within a contribution

Sometimes a contribution cannot be done with anonymised data. Then the contribution agreement applies:

- The organisation is the controller for any personal data it shares. It shares data only when anonymised data will not do, and only if it may lawfully share it with the professional in their country.
- The professional acts as a volunteer under the organisation's authority, uses the data only on its instructions, and deletes or returns it at handover, confirming this in Messages.
- Data is shared through a secure channel the organisation chooses, never through Handova. Passwords, card details, PINs and access codes are never shared on Handova. System access uses individual, limited accounts removed when the work ends.
- Personal or confidential data never goes into AI tools, and never into personal accounts without the organisation's written permission.
- Either party reports a suspected breach to the other and to Handova within 24 hours. The organisation decides on notification as controller; Handova helps (Annex C).

Handova does not see or store this data and is not a party to the contribution.

SECTION 07

Sharing, processors and international transfers

Other users. Handova connects people across countries. A published profile can be seen by anyone, anywhere. Applications, messages and agreements are seen by the members of the organisation concerned, who may be in another country. We explain this in the privacy notice before people publish or apply. The legal basis for these user-to-user transfers is that they are necessary for the contract the person asked for: publishing a profile or applying.

Processors. Before using a provider that processes personal data for Handova, the privacy lead checks its security, makes sure a data processing agreement is in place, records where it processes data, and makes sure data is deleted at the end of the service. Current providers and their agreements are in Annex A.

Transfers outside the EEA. We transfer personal data to a provider outside the EEA only with an adequacy decision (including the EU–US Data Privacy Framework for certified companies) or standard contractual clauses with a transfer risk assessment. Annex A records the safeguard for each provider.

Authorities. We report to the relevant authorities where the law requires it, or where someone is in immediate danger. The privacy lead decides, records the reason and shares the minimum.

SECTION 08

Security

Administrator access - Every administrator account uses two-step sign-in. - Administrators get the least access their task needs. Access is reviewed every six months and removed the day someone leaves the role. - Administrators read a conversation only once it, or its contribution, has been reported. The platform enforces this. - Only administrators see the name on an identity document, signature evidence (email, IP address, browser) and report case notes. - Admin actions (suspensions, take-downs, frozen conversations, closed contributions, report decisions) are logged. - Direct database or dashboard access (Supabase) is limited to the privacy lead, used only for maintenance or an incident, and recorded in the admin log. - Secret keys (database service key, Didit, email) are stored only as provider secrets, never in code or documents, and rotated after any suspected exposure.

Everyone with access - Use strong, unique passwords and two-step sign-in on every work account, including email. - Use updated, encrypted devices with screen lock. - Copy Handova data out of the platform only when the task needs it; delete local copies when done. - Never put personal, confidential, report, identity or safeguarding information into AI tools. - Report phishing or anything suspicious straight away.

Platform measures. Row-level security controls who can read each record. Messages cannot be edited or deleted. The site uses HTTPS. Sign-in and identity checks are rate-limited.

SECTION 09

Retention

We keep data only as long as needed. The full schedule is in Annex A. In short:

- **Account and profile:** until the person deletes the account. Profiles closed for inactivity are kept unpublished so they can be reopened, and are deleted after 24 months without sign-in, after a reminder.
- **Signed platform and contribution agreements, with signature evidence:** six years after the account closes, then deleted automatically.
- **Contribution records** (need, hours, deliverables, endorsement, questionnaire answers), kept by the organisation with the professional shown as "Former member": six years after the account closes, then deleted.
- **Messages:** deleted with the account, except in conversations linked to a contribution or a report, which are kept six years after the last message.
- **Identity checks:** Handova's record is deleted with the account. Didit keeps the session, including images, for up to one year under our current setting, and deletes it earlier when the account is deleted.
- **Reports of concern:** six years after the case closes, or longer if legal proceedings are ongoing or expected. Cases involving a child are kept until the child turns 25 or for six years after closure, whichever is later. Then deleted. Reviewed once a year. Only the safeguarding lead, and the independent contact for cases about the founder, can see them.
- **Notification email log:** 12 months.
- **Admin action log:** six years.
- **Rights requests and breach records:** three years after closure, stored in Handova's secure records.
- **Analytics:** event data two months; cookies up to two years unless withdrawn.

At each annual review the privacy lead checks that automatic deletion jobs ran.

SECTION 10

Rights and how we handle requests

People can ask to access, correct, erase, restrict or port their data, object to its use, withdraw consent, and ask for human review of any automated decision. They can complain to the data protection authority where they live or work.

Many rights are self-service: people can edit or unpublish their profile, turn off emails and delete their account from Account and privacy. Other requests go to hello@handova.org.

How we handle a request 1. The privacy lead logs it: date received, person, request, deadline, actions, date closed. 2. We confirm identity proportionately, normally by replying to the account's email address. We do not ask for ID documents for this. 3. We respond within one month, free of charge. For complex requests we may extend by up to two months and tell the person why within the first month. 4. We refuse only manifestly unfounded or excessive requests, and explain how to complain. 5. If erasure is limited (for example signed agreements kept six years), we say what we keep, why and until when. 6. If a request concerns data an organisation controls under a contribution, we pass it to that organisation and tell the person. 7. If a request concerns the privacy lead herself, the independent contact (**to be confirmed soon**) oversees it.

We will expand this procedure as Handova grows.

SECTION 11

Automated decisions and AI

Handova makes no significant decision about anyone by automated means alone. Automatic checks (such as the name match in the identity check, or the inactivity rule) only flag cases or send reminders; a person reviews every rejection, removal or suspension. Where Handova restricts or removes an account or content, we tell the person why and how to ask for a review. Personal, confidential, report, identity or safeguarding information is never entered into AI tools.

SECTION 12

Children

Handova is for people aged 18 and over; professionals confirm their age before publishing. We do not knowingly collect children's data. If a user is under 18, we close the account and delete the data, keeping only what a safeguarding concern needs. A need involving children's personal data is taken down and treated as a safeguarding concern.

SECTION 13

Email, notifications and cookies

Notification emails are part of the service and can be turned off in Account and privacy. Newsletters need prior opt-in and an easy unsubscribe. Google Analytics loads only after "Accept analytics"; declining is as easy as accepting, and the choice can be changed at any time.

SECTION 14

Personal data breaches

Anyone who suspects a breach reports it immediately, and within 24 hours at the latest, to hello@handova.org. The privacy lead follows Annex C, records every breach, and decides within 72 hours whether to notify the relevant supervisory authority and the people affected.

SECTION 15

Obligations of the team, volunteers and contractors

Everyone with access to Handova data signs a confidentiality commitment (which continues after they leave), uses data only for their task, follows section 8, and reports breaches, concerns and rights requests the same day. Breaches of this policy can lead to removal of access and of the role. Concerns about misuse of data can also be raised under the Whistleblowing Policy and Procedure, at safeguarding@handova.org.

For the future. As Handova grows, we will add training for the team and short briefings for professionals and organisations.

SECTION 16

Review and related documents

The privacy lead reviews this policy and its annexes every year (next review October 2027), and sooner after a breach, a new feature that changes data flows, a new provider or a change in the law.

Related: privacy notice, cookie notice and terms of use (handova.org); professional, organisation and contribution agreements; and the Handova policy set: Safeguarding Policy and Procedure; Anti-Harassment, Intimidation and Bullying Policy and Procedure; Code of Conduct; Fraud, Bribery and Corruption Policy and Procedure; Whistleblowing Policy and Procedure; Independent Contact Role Note.

ANNEX A

Record of processing

Controller: Ethical Bridge LLC, registered in Wyoming, USA. Contact: hello@handova.org. Last updated: 20 October 2026.

Processors

PROVIDER	ROLE	LOCATION	AGREEMENT AND TRANSFER SAFEGUARD
Supabase	Database, sign-in, file storage, server functions	EU (Frankfurt)	Covered by Supabase's data processing agreement
Didit	Identity checks; Handova receives only the result and the name on the document	As set out in the provider's terms	Covered by Didit's data processing agreement
Hostinger	Mailbox hello@handova.org; sends sign-up and notification emails (SMTP)	As set out in the provider's terms	Covered by Hostinger's data processing terms

PROVIDER	ROLE	LOCATION	AGREEMENT AND TRANSFER SAFEGUARD
Google (Analytics)	Website usage, only with consent	Global, including the US	Covered by Google's data processing terms and the EU–US Data Privacy Framework
GitHub (Pages)	Website hosting; access logs	US	Covered by GitHub's data protection agreement and the Data Privacy Framework

Processing activities

#	PURPOSE	DATA	PEOPLE	LAWFUL BASIS	RECIPIENTS AND PROCESSORS	TRANSFERS	RETENTION
1	Accounts and sign-in	Email, hashed password, sign-in records	All users	Contract	Supabase; Hostinger (emails)	EEA; Hostinger as set out in its terms	Until account deletion
2	Professional profiles and review	Name, title, introduction, photo, country, time zone, languages, skills, experience and education entries (with logos), LinkedIn link, other link, monthly hours, 18+ and unpaid confirmations, review status	Professionals	Contract; review: legitimate interests	Public once published and approved; administrator; Supabase	Visible worldwide	Until deletion; closed profiles deleted after 24 months without sign-in, after a reminder
3	Organisation accounts	Name, country, city, type, website, summary, directory link, logo, staff size, members and representative's name	Organisation representatives	Contract; review: legitimate interests	Public once approved; administrator	Visible worldwide	While active; on last member's deletion the organisation is suspended, then deleted after 24 months, after a reminder to its directory contact. Signed agreements follow rows 4 and 7

#	PURPOSE	DATA	PEOPLE	LAWFUL BASIS	RECIPIENTS AND PROCESSORS	TRANSFERS	RETENTION
4	Platform agreement evidence	Name, role, email, hours committed, signing time, IP address, browser, version, full text and its SHA-256 hash, declarations ticked	Professionals, organisation signers	Legitimate interests (evidence, legal claims)	Signer; administrator	EEA	6 years after account closure, then automatic deletion
5	Needs and matching	Needs, applications, invitations, introductions, saved needs	Both	Contract	Organisation members and the professional concerned; administrator	Cross-border between users	Applications and saved needs: with account; needs: while the organisation's account is active, and needs linked to a contribution with the contribution record (row 8)
6	Messages	Messages and Handova system posts	Both	Contract; reported conversations: legitimate interests (safety)	Conversation parties; administrator only once reported	Cross-border between users	With account, unless linked to a contribution or report: 6 years after last message
7	Contribution agreements	Signed text and reference, name, email, role, safeguarding focal point name and contact, confirmations, language, signing time, IP address, browser, ID status at signing, text hash	Both	Contract; evidence: legitimate interests	Other party sees name, role, time and focal point; email, IP and browser seen only by signer and Handova	Cross-border between users	6 years after account closure, then automatic deletion

#	PURPOSE	DATA	PEOPLE	LAWFUL BASIS	RECIPIENTS AND PROCESSORS	TRANSFERS	RETENTION
8	Contribution record and impact CV	Hours (maximum 12 a day) and approvals, deliverables, completion, endorsement, confirmed skills, private note, "work again" answer and note, six-month "still in use" answer	Both	Contract; "work again": legitimate interests (better matches)	Organisation; professional; public only if the professional publishes; "work again" Handova only	Visible worldwide if published	6 years after account closure, then deleted
9	Questionnaires and profile basics	Answers including free text and the "anything uncomfortable?" answer, career stage, staff size	Both	Legitimate interests (learning); results only in totals	Administrator only	EEA	With the contribution record; deleted on request
10	Independent evaluation	Yes/no answer and date; name and email if yes	Both	Consent	Independent evaluator, once appointed, under a written agreement signed before any contact details are shared	Recorded here, with the safeguard, when the evaluator is appointed	Until withdrawn or evaluation ends
11	Identity verification	Handova: session ID, outcome, date, name on document. Didit: document images and data, selfie, face template	Professionals	Explicit consent	Didit (processor); administrator sees the document name	As set out in Didit's terms and data processing agreement	Handova: until account deletion. Didit: up to 1 year; earlier on account deletion

#	PURPOSE	DATA	PEOPLE	LAWFUL BASIS	RECIPIENTS AND PROCESSORS	TRANSFERS	RETENTION
12	Reports and case management	Reporter, target, reason, details, acknowledgement reference, case notes, decisions	Reporters, people reported	Legitimate interests (safety); legal obligation or vital interests where they apply	Safeguarding lead (Julieta Castiñeira de Dios); the independent contact for cases about the founder; authorities where required	As needed	6 years after the case closes, or longer if legal proceedings are ongoing or expected; cases involving a child until the child turns 25 or 6 years after closure, whichever is later. Then deleted. Reviewed yearly
13	Notifications and email	In-app notifications, email address, sent time, email preference	All users	Contract	Supabase; Hostinger	EEA; Hostinger as set out in its terms	In-app notifications: with account. Notification email log: 12 months
14	Website analytics	Page views (generic page names), approximate location, device and browser, cookie IDs	Visitors who accept	Consent	Google	US and elsewhere	Event data 2 months; cookies up to 2 years
15	Hosting and security logs	IP address, browser, request records	All visitors	Legitimate interests (security)	Supabase; GitHub	EEA; US	Provider periods (days to weeks)
16	Admin action log	Administrator, action, target, details	Users affected	Legitimate interests (accountability)	Administrator	EEA	6 years
17	Rights requests and breach log	Requester details, request, actions; breach details	Requesters; affected people	Legal obligation (accountability)	Privacy lead	Stored in Handova's secure records	3 years after closure

ANNEX B

Data protection impact assessment — Didit identity check

Status: approved with conditions by Julieta Castiñeira de Dios, 20 October 2026. **Decision:** approved with conditions (the mitigations in section 5). **Next review:** October 2027, or when the workflow or retention changes.

1. What the processing is

Before a first contribution agreement, a professional photographs a passport or ID card and records a live selfie on Didit's hosted page. Didit compares the faces (biometric data) and reads the document. Handova stores only the session ID, outcome, date and document name, and compares that name with the profile name; a mismatch goes to the administrator. Others see only an "ID verified" badge. Didit keeps sessions, including images, for up to one year; account deletion deletes them first.

2. Why a DPIA is needed

Biometric data for identification is special category data. The check is systematic, applies to people in many countries, and is a condition for taking part.

3. Necessity

Purpose: give organisations confidence that a professional is who they say they are; stop fake profiles; make it harder for someone removed for misconduct to return under another name.

Alternatives considered - LinkedIn and profile review only (already done): easy to fake. - Document without selfie: does not show the person holds it. - Video call with the administrator viewing the document: no biometrics, but takes time. Suitable for people who do not consent. - No check: falls short of the trust organisations need.

The automated check with a human alternative is the least intrusive option that achieves the purpose at scale.

4. Proportionality

- Only professionals, only once, only before their first contribution agreement.
- Handova never stores images, document numbers or dates of birth.
- Only the administrator sees the document name.
- Data is used only for identity assurance and related safety reviews, never for other purposes.
- Clear explanation and a consent screen before people reach Didit.

5. Risks and mitigations

RISK TO PEOPLE	LIKELIHOOD / SEVERITY	MITIGATIONS	RESIDUAL
Consent not freely given, because the check is required to sign	Likely / medium	**Offer a video-call alternative** with the administrator; say so on the consent screen and in the privacy notice	Low
Consent cannot be proven	Likely / medium	**Record consent** (time, notice version, wording shown) when a person selects "I consent"; consent can be withdrawn by email, triggering deletion of the Didit session	Low
Breach at Didit exposing documents and faces (identity theft)	Unlikely / high	Didit's data processing agreement; we check Didit's security certification and confirm in writing that it does not reuse our data to train models; we review Didit's retention setting every year and shorten it where the purpose allows	Low to medium
Wrongful failure (poor camera, face-matching errors that affect some groups more, name differences from transliteration, chosen names or marriage)	Possible / medium	No automatic rejection; administrator reviews mismatches; video-call alternative; person can write to us	Low

RISK TO PEOPLE	LIKELIHOOD / SEVERITY	MITIGATIONS	RESIDUAL
Exclusion of people without accepted documents (for example displaced people)	Possible / medium	Video-call alternative, with other reliable evidence of identity assessed case by case by the privacy lead	Low
Misuse of the document name by an administrator	Unlikely / medium	Admin-only access, two-step sign-in, admin action log	Low
Transfers outside the EEA	Possible / medium	Didit's locations and safeguards recorded in Annex A, as set out in its terms and data processing agreement	Low
Data kept longer than needed	Possible / medium	Deletion with account; retention setting reviewed yearly	Low
Fake status sent to Handova	Unlikely / medium	Webhook only triggers a fetch of the decision from Didit with our secret key	Low

6. Residual risk and decision

With the mitigations above in place, residual risk is assessed as **low to medium**. Prior consultation with a supervisory authority is not needed, because the residual risk is not high. Until consent recording and the video-call alternative exist, the risk is higher and the check must not be the only route to signing.

Decision: approved with conditions; the conditions are the mitigations in section 5. Signed: Julieta Castiñeira de Dios, founder and privacy lead, 20 October 2026.

ANNEX C

Personal data breach procedure

What counts as a breach

A breach is any security incident that leads to personal data being lost, destroyed, changed, disclosed or accessed without permission, or becoming unavailable. Examples: a platform bug that shows private answers or someone else's messages; an administrator or email account taken over; a leaked service key; an email sent to the wrong person; a breach at Supabase, Didit, Hostinger, Google or GitHub; a professional losing or misusing personal data an organisation shared for a contribution.

Who decides

The **privacy lead** decides on containment and notification. If she is unavailable for more than 12 hours, or involved, the **independent contact** (**to be confirmed soon**) decides. For serious or complex cases, Handova may bring in an external adviser or investigator. When an organisation is the controller (section 6), it decides on notification; Handova supports it and handles any part involving Handova's own data.

Today the privacy lead carries out every step below herself. We will expand this procedure as Handova grows.

Checklist

First hour - [ ] Whoever discovers it reports it to the privacy lead at once, by email to hello@handova.org. - [ ] Open an entry in the breach log; note the time we became aware. The 72-hour clock starts here. - [ ] Contain: rotate exposed keys or passwords, end sessions, remove access, suspend accounts, freeze conversations, take down content, or disable the affected feature. - [ ] Preserve evidence: keep logs and screenshots; do not delete records. - [ ] If someone is in danger, follow the Safeguarding Policy and Procedure first.

Within 24 hours - [ ] Establish what data, how many people, which countries, and whether special category, identity or safeguarding data is involved. - [ ] Assess the risk to people: identity theft, discrimination, physical harm, distress, loss of confidentiality. - [ ] Tell the processor or controller concerned, and ask for their findings. - [ ] Decide whether notification is needed and prepare messages.

Within 72 hours - [ ] Notify the relevant supervisory authority unless the breach is unlikely to result in a risk to people. If facts are missing, notify what we know and follow up. - [ ] Tell affected people without undue delay when the breach is likely to affect them, as the privacy notice promises, and always when the risk is high. Say what happened, what data, likely effects, what we have done and what they can do, and give a contact. - [ ] Record the decision and the reasons, including decisions not to notify.

Within 30 days - [ ] Close the incident, record lessons and fixes, and update this policy, Annex A or Annex B if needed.

Breach log template

FIELD	ENTRY
Reference	
Date and time we became aware; who reported	
What happened; date it started and ended	
Data and people affected (types, number, countries)	
Systems or providers involved	
Containment actions and times	
Risk assessment (none / risk / high risk) and reasons	
Authority notified? When, reference, or why not	
People notified? When, how, or why not	
Controller or processor informed	
Lessons and follow-up actions; owner; date closed	